



File No.: EXP202307805

RESOLUTION OF FILE OF ACTIONS

From the actions carried out by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: On April 24, 2023, a complaint was filed with registration number REGAGE23e00025972617 with the Spanish Agency for Data Protection against VODAFONE ESPAÑA, S.A.U. with NIF A80907397 (hereinafter, VODAFONE). The reasons for the complaint are as follows:

The complainant believes that the operator VODAFONE, of which she is a customer, has violated the protection of her personal data, as two individuals have attempted to fraudulently obtain her mobile device, using information related to the management of the return of said product.

Specifically, the complainant purchased a mobile device on 04/13/2023 and decided to return it on 04/19/2023. VODAFONE offered her two options for this: delivery at a post office or collection by courier at her home. The complainant chose the first option, received a code for the delivery, and went to the post office on the same day, 04/19/2023, where she was informed that they did not have the code and could not process the return. The complainant then contacted VODAFONE's customer service, where she was told that she needed to wait 24 hours for the code to be operational.

After this management, on the same day, 04/19/2023, she received a call from a person identifying himself as a VODAFONE operator, who knew her personal data and the details regarding the return of the product, offered to collect it from her home, and scheduled the delivery for that same afternoon.

After that call, the complainant contacted VODAFONE's customer service again, which informed her that the person she spoke with did not belong to the company and that the return had not been processed at her home.

Given the indications that this was a fraud, the complainant reported the events to the police, who arrested the two individuals who showed up at her home to collect the mobile device, providing her with a delivery note from Correo Express with the same identification code that VODAFONE had given her.

The next day, 04/20/2023, she received a call from a phone number with a similar number, which she did not answer for fear that it was the same individuals.

The complaint is accompanied by screenshots of SMS and WhatsApp messages exchanged with VODAFONE, the received call, and a copy of the police report filed on 04/20/2023.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the complaint was forwarded to VODAFONE for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The transfer, which was carried out in accordance with the regulations established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was done through the Single Enabled Electronic Address (DEHÚ) service, which certifies that the notification was accepted on 06/14/2023.

On 07/20/2023, this Agency received a written response, signed by the DPD of VODAFONE. In its response, VODAFONE states that the reported events were carried out by individuals unrelated to VODAFONE's activity and that the company also considers itself a victim of an attempted fraud, for which it filed the corresponding report with the police on 05/12/2023.

It provides information regarding its protocols for managing returns of mobile devices. In this regard, it states that the personnel handling requests are agents from the so-called call center and that, for their management, VODAFONE has established a procedure that would be available internally through the

“Red Planet” Platform, where all applicable procedures for agents are housed, this being one of them. It provides a copy of an excerpt from the procedure addressing the “return of non-presential channel.” Among the different options, it includes the return at Correos, indicating “the customer must go to the office 24 hours after receiving the SMS with the delivery code.”

Furthermore, VODAFONE states that it has conducted specific training for the personnel of the aforementioned call centers who process requests by phone and that it sent a communication with the aim of “informing customers that, if they choose the return via Correos, they will never receive a call from Vodafone to change the shipping method to collection at the customer's home.” A screenshot of the communication is provided, although it does not include a date or recipients of the sending, as well as a notice for a meeting regarding “Logistics and Returns” scheduled for 12/13/2023.

Regarding the causes that could have generated the incident, it provides screenshots of the actions taken concerning the return of the mobile device in the software application used for its management. It also states that it has no record of a call received by the complainant from the number and time frame indicated, but from another number, which leads it to suspect that it may be due to telephone identity theft (spoofing).

Finally, it attaches a copy of the letter addressed to the complainant informing her of the analysis carried out by the company.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
3/8

THIRD: On July 24, 2023, in accordance with Article 65 of the LOPDGDD, the complaint submitted was admitted for processing.

FOURTH: The General Subdirectorate for Data Inspection (hereinafter, SGID) proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions established in Title VII, Chapter I, Section Two, of the LOPDGDD. In these actions, the following points have been noted:

VODAFONE states that the call centers managing returns would act as data processors and provides a copy of the contract signed between VODAFONE PROCUREMENT COMPANY S.À R.L., based in Luxembourg, and the entity ZEDCHAIN INTERNATIONAL LOGISTICS S.L., whose headquarters are in Spain, as a "supplier," which includes an annex dedicated to data protection.

It states that, up until the moment the complainant contacted the customer service to report that they had been unable to use the code at the post office, the process had been in accordance with their protocols and carried out normally.

Regarding that process, it indicates:

“For these purposes, access to the complainant's file that was made prior to and during the course of the fraud has been audited, and it has been verified that all recorded accesses are legitimate and made by employees or collaborators with the corresponding permissions and related to previous interactions that justify such accesses.”

It provides an extract of the accesses by different agents to the complainant's profile, along with the record of each interaction made. The documentation provided regarding the interactions includes details of the same and a copy of the conversation.

Regarding the call received by the complainant afterwards, VODAFONE confirms that similar cases have occurred:

“After analyzing Vodafone's internal systems, my client has been able to establish a link between the complainant's case, the number ***TELEFONO.1, and another sixty-two (62) similar cases.”

However, VODAFONE states that it is not responsible for the incident and was not aware of it until the complainant brought it to light:

“Neither the call nor the change of return method was made by an authorized representative of Vodafone, but by third parties unrelated to Vodafone who sought to profit from the illicit acquisition of

the device that A.A.A. wanted to return. This attempt was discovered at the moment the complainant called my client's Customer Service and was informed that the operation they were describing had not been carried out by Vodafone."

VODAFONE states that it has both general security measures ("measures implemented by Vodafone to reinforce the security of its customers' data in general, not specifically developed to mitigate fraud in device returns") and specific measures for this particular case.

Among the general security measures, it reports the following:

- (...)

Regarding specific measures, the defendant indicates the following:

- (...)

It also states that there may be leaks over which it believes it cannot have control:

"It cannot be expected of my client to maintain control and security measures that eliminate the possibility of corrupt agents memorizing certain customer data and collaborating with organized criminal gangs that carry out the described fraud. This criminal practice would be beyond my client's control and therefore beyond the level of responsibility that can be demanded of it."

Regarding the origin of the call received by the complainant, the investigative actions have sought to clarify the origin and actual number of the fraudulent call, as well as the ownership of that line.

Regarding the number ***TELEFONO.1, from which the complainant was apparently contacted for the attempted fraud on April 19, 2023, information was requested from the operator Least Cost Routing Telecom, S.L. (hereinafter, LCRT), to which that number is associated according to the record provided by the National Commission of Markets and Competition, which has stated the following:

"Having reviewed our call registration system (...) no calls were made from the line ***TELEFONO.1 on April 19, 2023," and that the line has been subassigned since February 6 to the reseller STG GROUP, S.A.C., with a legal address in Peru.

The same verification was carried out with STG GROUP, S.A.C., through its representative in Spain, who also stated that no calls were made from that line: "Having reviewed the call registration system for billing purposes of STG GROUP, there are no outgoing calls from the line ***TELEFONO.1 on April 19, 2023. The inquiry has also been forwarded to the Operator, and they also do not show calls from the indicated line on the specified date; therefore, we have no record of calls being made." They also indicate that the line is contracted by an entity whose legal address is also in Peru: "The line ***TELEFONO.1, on April 19, 2023, is contracted by the Subscriber ORBE TELECOMUNICACIONES S.A.C."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/8

From the investigative actions, it was concluded that,

"Given the absence of evidence regarding the call made from the number ***TELEFONO.1, it would be established that the fraudulent call to the claimant was indeed made from a different line, masked using the technique of spoofing, thus displaying the number ***TELEFONO.1 on their terminal, as provided in the documentation of the claim."

Efforts have been made to ascertain the possible real number of the call, but it has not been possible to obtain it from these third parties due to this masking. LCRT states in this regard: "If we are not provided with the fixed telephone line reported (from which the complainant indicates they received the call), we have no way to locate in our call record system (HEOS) whether a call was made to the number ***TELEFONO.2 on April 19, 2023."

Finally, the entity VOXBONE, S.A. has been repeatedly requested for information regarding the ownership of the line ***TELEFONO.3 and the calls made on April 19, 2023. It has not been possible to successfully contact this entity through the requests issued by this Agency, and therefore it has not been possible to verify these aspects.

Lastly, the Preliminary Investigation Report from the SGID includes the corrective measures adopted by VODAFONE to try to prevent this type of:

-
(...)

Finally, the Investigation Report concludes that

“With regard to the possible exfiltration of the claimant's data, it has not been possible to determine the origin; the respondent denies any responsibility for this event and states that it too would be a victim of this type of fraud. An internal audit of the accesses related to this case has been conducted, without finding evidence of unauthorized access or irregularities that would indicate a leak.

In any case, the data used by the malicious third parties was in the possession of the respondent, and they acknowledge possible risks that would be beyond their control: “It cannot be expected of my represented party to maintain control and security measures that eliminate the possibility of corrupt agents memorizing certain customer data and collaborating with organized criminal gangs that carry out the described fraud.”

Information has been gathered regarding the existing security measures, most of which are aimed at the transversal security of the personnel attending this telephone channel. Measures are contemplated to prevent the leakage and/or export of customer data.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/8

LEGAL GROUNDS

I

Competence

In accordance with the functions conferred to each supervisory authority by Article 57.1 a), f), and h) of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR) and as provided in Articles 47 and 48.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter LOPDGDD), the Presidency of the Spanish Agency for Data Protection is competent to resolve these investigative actions.

Furthermore, Article 63.2 of the LOPDGDD states: “The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures.”

II

Security of Processing

Article 32 of the GDPR stipulates the following:

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which in particular includes, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data promptly in the event of a physical or technical incident;
- d) a process for regularly testing, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification

mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
7/8

4. The data controller and the data processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data can only process such data following the instructions of the controller, unless required to do so by Union law or the laws of the Member States."

III

Integrity and confidentiality

Letter f) of Article 5.1 of the GDPR states:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures an appropriate level of security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures ('integrity and confidentiality')."

IV

Conclusion

Regarding the possible exfiltration of data, it has not been possible to determine its origin. VODAFONE admits the possibility that "corrupt agents may memorize certain customer data and collaborate with organized criminal gangs that carry out the described fraud," considering that these are risks that would be beyond its control. In this regard, and considering that more similar cases have occurred (up to 62 according to VODAFONE), it is worth questioning whether adequate measures have been taken to ensure data security.

In this sense, VODAFONE has documented the adoption of measures against this type of case. These measures, detailed in the previous sections, include:

- The existence of a specific procedure for managing returns that includes specific references to the case subject to this claim.
- The existence of a computer tool for managing returns that allows for traceability of access to customer data, in which, after the internal audit conducted by the company, there are no records of unauthorized access or irregularities that indicate a leak.
- The existence of workplace protocols specifically designed to hinder data leakage.
- Training of personnel who handle data, as well as a specific reminder regarding the case subject to the claim.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

8/8

In summary, from the investigated facts, it has not been possible to determine the origin of the data leak, and therefore there is no evidence to confirm the liability of the party being claimed against. All of this is without prejudice to any subsequent actions that this Agency may carry out, applying the investigative and corrective powers it holds.

Thus, as it has not been possible to verify a breach by VODAFONE of the obligation to ensure the integrity and confidentiality of the data, nor of the obligation to have adequate security measures in processing, in accordance with the aforementioned, by the Presidency of the Spanish Agency for Data Protection, IT IS

AGREED:

FIRST: TO PROCEED TO FILE the present proceedings.

SECOND: TO NOTIFY this resolution to VODAFONE ESPAÑA, S.A.U. and to the claiming party.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure as provided for in Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, and in accordance with the provisions of Articles 112 and 123 of the aforementioned Law 39/2015, of October 1, the interested parties may optionally file a motion for reconsideration before the Presidency of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the

Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and paragraph 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

940-301023

Olga Pérez Sanjuán

Deputy Director General of Data Inspection, in accordance with Article 48.2 LOPDGDD, due to vacancy of the Presidency and Deputy Presidency of the AEPD

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es